

Agent Control Matrix

Preventive and detective controls for the AP agent layer

Product	AP Agent OS
Tier	Professional
Version	1.0
Date	September 2026
Use	Implementation toolkit

Responsibility is earned.

How to use

One row per risk, not per slogan. Copy into the Excel control matrix and assign owners. Frequency: C = continuous, D = daily, W = weekly, M = monthly, Q = quarterly.

Agent	Risk	Control	P/D	Human owner	Evidence	Freq	Escalation trigger
All	Unclear accountability	Named owner on charter; RACI	P	Head of AP	Signed charter	Q	Owner vacant >5 days
All	Agent exceeds authority	Autonomy level + action allow-list	P	Agent owner	Versioned charter	C	Any off-list action
All	SoD conflict	Operator ≠ sole payment releaser	P	Controls	SoD matrix	Q	Combined access found
All	Excess privilege	Least-privilege system role	P	IAM + tool owner	Access review	Q	Write access at Level 0/1
All	Confidential data in public model	Approved model list; DLP	P	Security	Model inventory	C	Unapproved endpoint
All	Prompt injection	Untrusted-data handling; EX-PIJ	P/D	Security + owner	Quarantine log	C	Any EX-PIJ
All	Hallucinated facts	Source-ID rule; reject uncited numbers	P	Agent owner	Output schema validation	C	Number without ID
All	Silent model change	Change control + retest pack	P	Tool owner	Release ticket	Per release	Prod change without ticket
All	Unlogged activity	Immutable audit log	D	IT / AP systems	Log completeness test	W	Gap in sequence
All	Override abuse	Reason code + second line review	D	Controls	Override report	W	Override rate > threshold
All	No fallback	Documented revert to manual	P	Head of AP	BCP note	Q	Cannot pay without agent
01 Intake	Phishing / malware	Secure intake path; no macro execute	P	IT	Security design	C	Suspicious attachment
01 Intake	False complete	Human sample of "complete"	D	Intake lead	Sample sheet	W	False-complete > target
02 Validation	Wrong vendor selected	No auto vendor create; dual control on fuzzy vendor	P	MDM	Ticket trail	C	Fuzzy match accepted solo

Agent	Risk	Control	P/D	Human owner	Evidence	Freq	Escalation trigger
03 Matching	Forced incorrect match	Deterministic engine first; ban unmatched line pairing	P	Match lead	Match config	C	Forced match without GR
04 Triage	Misroute high-risk codes	High-risk codes (DUP, BANK, DOA, TAX) dual-classified	D	Ops manager	Recode report	D	High-risk recode
05 GR	Auto-receipting	System cannot post GR from this agent	P	GRNI lead	Role design	C	Any GR post by agent
06 PO quality	Punitive buyer comms	Drafts only; Procurement tone guide	P	Procurement ops	Sent-mail review	M	Complaint
07 Approval	Auto-approve	Agent has no approve permission	P	Workflow lead	Role design	C	Any agent approval
08 Supplier	Unreviewed send / legal admission	Human send default; banned phrases list	P	Query lead	Send log	C	Send without approval
09 Internal	Harassment / over-chase	Cadence caps; no C-level unprompted	P	Ops manager	Cadence config	W	Cap breach
10 Anomaly	Fraud allegation / FN miss	Language: "candidate" only; seeded recall tests	P/D	Controls	Gold set	M	Seeding miss
11 Statement	Booking from statement	No posting rights	P	Statements lead	Role design	C	Any post
12 Pay review	Agent releases payment	Technically impossible role; dual human release	P	Payments mgr	Payment SoD	C	Any agent in release path
12 Pay review	Missed bank-change	Require change-log join before "clear"	P	Payments + Controls	Review pack	C	Clear despite open bank change
13 Close	Invented accrual	Accrual candidates must have source IDs	P	Close lead	Pack	Period	Amount without ID
14 Reporting	Silent number reuse	Fail closed if query fails	P	Analytics lead	Pack exception	C	Prior period shown as current
15 Root cause	Blame culture	Hypothesis language; no HR file access	P	Process excellence	Pack review	M	Named blame without test
16 Orchestrator	Self-promotion	Cannot change autonomy records	P	Head of AP	Permission	C	Self-authored promotion

Agent	Risk	Control	P/D	Human owner	Evidence	Freq	Escalation trigger
All	Retention / leaving staff	Access joiners-movers-leavers	P	IAM	JML ticket	C	Leaver still admin

Risk register (top 12)

- 1. Payment released on agent advice without human review
- 2. Duplicate payment
- 3. Vendor bank diversion
- 4. Prompt injection from supplier documents
- 5. Tax mis-coding at scale
- 6. Privacy leak to a consumer model
- 7. Hallucinated supplier balance
- 8. Approval spoofing
- 9. Shadow prompt changes
- 10. Over-automation of GR
- 11. Workforce deskilling with no fallback
- 12. Overstated benefits (vanity AI volume)

This material is an implementation toolkit. It is not legal, tax, accounting, audit or investment advice. Agents do not authorise payments. Humans remain accountable. Statistics are cited in the Research Ledger.